

Estándares y Metodologías

Banco Ther S.A



UNIVERSIDAD
CATÓLICA
BOLIVIANA

Carrera: Ingeniería de Sistemas

Materia: Auditoria de Sistemas

Semestre: 9no Semestre

Integrantes:

García Aguirre Ignacio

Mattos Terán Fernanda

Pimentel Silva Jared

Quenta Ramos Ramiro

Valenzuela Rivera Mateo

Fecha: 3/3/2026

1 ITIL (INFORMATION TECHNOLOGY INFRASTRUCTURE LIBRARY)

1.1 Definición

ITIL es el marco de trabajo de mejores prácticas más aceptado a nivel mundial para la Gestión de Servicios de Tecnologías de la Información (ITSM). Su objetivo principal es alinear los servicios de TI con las necesidades estratégicas del negocio, garantizando que la tecnología entregue valor real y optimice los recursos. A diferencia de otros marcos, se enfoca directamente en la operación y entrega del servicio mediante un Sistema de Valor del Servicio (SVS) que fomenta la mejora continua. (Atlassian. (s.f.), 2026)

1.2 Aplicación en el banco

En Banco Ther S.A., se aplica principalmente para estandarizar la atención y operación de los servicios diarios, gestionando incidentes, peticiones de los usuarios y cambios en la infraestructura.

1.3 Áreas en que se aplica

Esta normativa se aplica a las siguientes áreas:

- Subgerencia de Operaciones y Soporte: Liderado a través del “Encargado de Operaciones” y el “Analista de Soporte Técnico” en la mesa de ayuda.
- Subgerencia de Infraestructura y Telecomunicaciones: Para resolver fallas en servicios críticos o enlaces de red.

2 OWASP (OPEN WORLDWIDE APPLICATION SECURITY PROJECT)

2.1 Definición

OWASP es una fundación dedicada a mejorar la seguridad del software a nivel mundial, proporcionando recursos gratuitos y estándares como el OWASP Top

10 y el ASVS. Al no estar afiliada a ninguna empresa, ofrece información imparcial y se ha convertido en el estándar de referencia en la industria para desarrolladores y auditores que buscan proteger aplicaciones contra vulnerabilidades críticas. (OWASP Foundation, 2025)

2.2 Aplicación en el banco

Se aplica en todos los activos donde exista desarrollo, configuración y operación de aplicaciones, como la Banca Web, la App Móvil y las integraciones de APIs, con el objetivo de reducir riesgos en los servicios digitales.

2.3 Áreas en que se aplica

Esta normativa se aplica a las siguientes áreas:

- Subgerencia de Desarrollo de Sistemas: Donde el “Arquitecto de Software” y los “Analistas Programadores” deben programar de forma segura.
- Subgerencia de Aseguramiento de Calidad: Donde el “Encargado de QA” y el “Analista de Pruebas” utilizan estas guías para testear y certificar el software antes de su liberación.

3 PCI DSS (PAYMENT CARD INDUSTRY DATA SECURITY STANDARD)

3.1 Definición

PCI DSS es un estándar de seguridad diseñado específicamente para proteger los datos de cuentas de tarjetas de pago en aquellos sistemas que almacenan, procesan o transmiten esta información sensible. Establece requisitos técnicos operativos, como la construcción de redes seguras, el uso de criptografía y la gestión de vulnerabilidades, para reducir el riesgo de fraude o filtración de datos financieros. (PCI Security Standards Council., 2022)

3.2 Aplicación en el banco

Esta normativa se aplica en el entorno de datos del titular de tarjeta (CDE), abarcando los canales de pago, la Banca Web, las pasarelas y la red que transporta estas transacciones.

3.3 Áreas en que se aplica

Esta normativa se aplica en las siguientes áreas:

- Seguridad de la Información: supervisa el cumplimiento de dicha normativa.
- Subgerencia de Infraestructura y Telecomunicaciones: Donde el “Administrador de Redes” y el “Administrador de Servidores” implementan la segmentación de red y firewalls.
- Subgerencia de Operaciones y Soporte: Donde el “Encargado de Gestión de Accesos” restringe quién puede ver la información de las tarjetas.

4 NIST (NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY)

4.1 Definición

NIST es un conjunto de marcos y guías desarrollados para gestionar de forma integral la ciberseguridad y el riesgo tecnológico en las organizaciones. Estas publicaciones proporcionan un ciclo de gestión de riesgos y un catálogo de controles de seguridad que integran la protección tecnológica con la estrategia institucional y la gobernanza corporativa. (Quinn, 2024)

4.2 Aplicación en el banco

Se utiliza como la principal referencia técnica para estructurar el gobierno de ciberseguridad y estandarizar los controles de protección sobre los activos críticos (core bancario, bases de datos, redes, etc.).

4.3 Áreas en que se aplica

Esta normativa se aplica en las que se aplica:

- Subgerencia de Infraestructura y Telecomunicaciones: Es la encargada de aplicar los controles de la fase de "Protección", implementando la segmentación de red, el endurecimiento de servidores y la seguridad perimetral para proteger la infraestructura crítica. Esto involucra directamente al "Administrador de Redes" y al "Administrador de Servidores".
- Subgerencia de Operaciones y Soporte: Aplica los controles de seguridad sobre los servicios de identidad y el monitoreo. A través del "Encargado de Gestión de Accesos", implementan controles como la autenticación multifactor, y mediante el "Operador de Backup y Continuidad", ejecutan la fase de "Recuperación" gestionando respaldos y el Plan de Recuperación ante Desastres.
- Unidad de Administración de Datos: Se encarga de implementar los controles técnicos de seguridad y protección directamente sobre las bases de datos transaccionales del banco.
- Subgerencia de Desarrollo de Sistemas: Aplica los lineamientos de categorización de sistemas y selección de controles de seguridad en los canales digitales (Banca Web y App Móvil) y en el Core Bancario.

5 BIBLIOGRAFÍA

Atlassian. (s.f.). (2026). Obtenido de Guía esencial de ITIL y la gestión de servicios de TI (ITSM).: <https://www.atlassian.com/es/itsm/itil>

OWASP Foundation. (2025). Obtenido de OWASP Top Ten Web Application Security Risks: <https://owasp.org/www-project-top-ten/>

PCI Security Standards Council. (2022). Obtenido de Document library.: https://www.pcisecuritystandards.org/document_library/

Quinn, S. (2024). *NIST Cybersecurity Framework 2.0 for ERM practitioners*. Obtenido de National Institute of Standards and Technology.: <https://doi.org/10.6028/nist.sp.1303.ipd>